Recommandations à la direction

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-72 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Synthèse des travaux de gouvernance : `ebios-rm.md`, `services-critiques.md`, `nis2-dora.md`, `rto-rpo.md`, `pca-pra.md`. Les mesures citées comme preuves seront renseignées après les essais (WOR-79) ; d'ici là, elles sont marquées à mesurer.*

Synthèse pour la direction

1. **Un arrêt de paiement coûte peu pendant 5 minutes, puis le coût explose.** Une heure d'arrêt en pointe coûte environ 700 k€, essentiellement en pénalités contractuelles, et déclenche probablement une notification à l'ACPR au titre de DORA.
2. **La reprise automatique est donc l'investissement prioritaire.** Le démonstrateur vise un retour du service vérifié en moins d'une minute sur un déni de service, contre 30 minutes ou plus pour une reprise manuelle.
3. **Elle ne suffit pas pour une attaque sur l'intégrité des données.** Une injection impose de préserver les preuves, de vérifier les données et de notifier, même si le service revient vite. L'automate ne doit pas décider seul dans ce cas.
4. **Le démonstrateur repose sur un seul serveur.** C'est acceptable pour prouver le principe, pas pour la production : un deuxième site et des sauvegardes hors site sont la première dépense à prévoir.
5. **Nous demandons trois décisions** à la direction (dernière section).

0. Avant toute recommandation : ce que l'équipe doit livrer d'ici les essais

Au 20/10, plusieurs mécanismes sur lesquels reposent ces recommandations ne sont pas encore codés : moteur de remédiation, modèle de détection, sauvegarde de la base ; et dans le socle, l'API garde ses données en mémoire, donc un redémarrage les perd. Sans eux, les éléments vérifiables cités ci-dessous resteront vides. La liste priorisée est dans `constat/etat-implementation.md` §4.

1. Les arbitrages que nous avons faits

Arbitrage	Ce que nous avons choisi	Ce que nous avons écarté	Pourquoi	Ce que ça coûte
Quoi protéger d'abord	La chaîne de paiement : API, base, authentification, WAF	Protéger tous les services au même niveau	Ce sont eux qui portent le revenu et l'engagement envers les 200 partenaires	L'assistant RAG et la consultation passent après
Automatique ou humain	Automatique pour les actions réversibles (limitation, redémarrage) ; un humain valide les actions destructrices et les incidents d'intégrité	Tout automatiser, ou tout faire valider	La vitesse compte pour la disponibilité ; une restauration à tort coûte plus cher qu'une minute d'arrêt	Une injection est traitée moins vite qu'un déni de service
Vitesse ou preuves	Copier les journaux et la base compromise **avant** de restaurer	Restaurer au plus vite	Sans preuves, pas d'investigation ni de notification DORA crédible	Quelques secondes de plus sur la reprise

Arbitrage	Ce que nous avons choisi	Ce que nous avons écarté	Pourquoi	Ce que ça coûte
Scénario principal de la démo	Déni de service (risque R1) ; injection en second scénario	Une seule attaque	R1 est le risque le plus élevé ; le second scénario montre que la réponse dépend du type d'incident	Deux chaînes de remédiation à construire et tester
Hébergement	Tout sur un hôte, sans dépendance à un cloud	Services managés	Imposé par le cadre du projet ; évite aussi le risque lié à un prestataire	Point de défaillance unique, assumé et documenté
Restauration après injection	*À trancher* : snapshot seul, ou snapshot et rejeu des transactions légitimes	—	Le snapshot seul perd des transactions confirmées (objectif : zéro)	Le rejeu demande un journal des transactions
Référentiels	DORA, EBIOS RM ; NIS2 en grille de lecture	PCI DSS	Aucune donnée de carte manipulée	—

2. Recommandations

Chaque recommandation repose sur un élément **vérifiable**, issu de nos essais ou de nos documents.

Priorité 1 — à décider maintenant

#	Recommandation	Élément vérifiable	Effort
REC-1	**Généraliser la reprise automatique** aux incidents de disponibilité sur toute la chaîne de paiement	RTO mesuré sur 3 essais, pire cas retenu (*à mesurer*) ; nombre d'interventions humaines pendant les répétitions : objectif 0 (WOR-78)	Moyen
REC-2	**Garder un humain dans la boucle pour les incidents d'intégrité** : blocage automatique, mais restauration et notification validées par une personne	Fiche S2 du PCA ; délai entre l'alerte et la décision humaine, à mesurer en exercice	Faible
REC-3	**Exiger deux signaux concordants** avant toute action destructrice	Taux de faux positifs du modèle ML (WOR-52) ; nombre de remédiations à tort pendant le chaos engineering (WOR-76) (*à mesurer*)	Faible
REC-4	**Encadrer le moteur de remédiation** comme un bien critique : périmètre d'actions limité, appels authentifiés, journalisation	Revue des droits du moteur (WOR-64) ; essai d'appel depuis un composant non autorisé, qui doit être refusé	Moyen

Priorité 2 — dans les 6 mois

#	Recommandation	Élément vérifiable	Effort
REC-5	**Sauvegardes hors site et immuables**, avec restauration testée chaque trimestre	Temps de restauration mesuré ; nombre de transactions perdues à la restauration	Moyen
REC-6	**Restauration de la base à un instant précis** (archivage continu des journaux de la base), pour tenir zéro transaction perdue après une injection	Essai d'injection suivi d'une restauration, sans transaction légitime perdue	Moyen
REC-7	**Procédure de notification DORA** : classification, brouillon préparé à partir des journaux, validation, envoi à l'ACPR	Exercice de notification chronométré face aux délais réglementaires	Faible

#	Recommandation	Élément vérifiable	Effort
REC-8	**Programme annuel de tests de résilience** couvrant tous les risques retenus dans l'EBIOS, pas seulement le scénario de démo	Taux de couverture des risques R1 à R8 par au moins un test	Moyen

Priorité 3 — dans les 12 mois

#	Recommandation	Élément vérifiable	Effort
REC-9	**Deuxième site** (ou deuxième zone de disponibilité), avec bascule testée	Durée de bascule mesurée	Élevé
REC-10	**Protection anti-déni de service en amont** du WAF, pour les attaques distribuées	Essai de charge distribuée	Moyen, souvent sous forme de service
REC-11	**Gestion des prestataires TIC selon DORA** : registre, clauses contractuelles, plans de sortie	Registre à jour, contrats revus	Moyen

Ordre de grandeur pour arbitrer : un seul incident de 30 minutes à 2 heures en pointe coûte environ 700 k€ (`services-critiques.md`). Les priorités 1 et 2 visent à ce qu'il ne se produise pas ; la priorité 3 protège contre la perte complète du site.

3. Ce que nous ferions autrement en contexte industriel

Dans le démonstrateur	En production
Un seul hôte, sauvegardes locales	Deux sites, sauvegardes hors site et immuables
Un modèle ML entraîné sur quelques dizaines de minutes de trafic	Plusieurs semaines de données réelles, réentraînement régulier, suivi de la dérive du modèle
Deux scénarios d'attaque, joués par l'équipe	Programme de tests annuel, tests d'intrusion par des testeurs indépendants (TLPT si l'entité est désignée)
Notification décrite sur papier	Procédure exercée, astreinte conformité, modèles de rapports ACPR
Rôles fictifs (directeur de crise, RSSI, DPO)	Rôles nommés, suppléants, exercices de crise deux fois par an
Hypothèses financières fictives	Analyse d'impact sur l'activité menée avec les métiers et la finance
Gouvernance portée par l'équipe projet	Cadre de risque TIC approuvé par l'organe de direction, comme l'exige DORA (art. 5)

4. Limites de cette analyse

- Les chiffres financiers sont **fictifs**. Ils donnent des ordres de grandeur, pas un budget.
- Les seuils DORA et les délais de notification sont repris de notre lecture des textes, à confirmer par un juriste.
- Les temps de reprise ne vaudront preuve qu'une fois mesurés (WOR-79). Si les mesures ne tiennent pas les objectifs, les recommandations REC-1 et REC-3 seront revues.

5. Décisions demandées à la direction

1. **Valider le principe d'une reprise automatique** pour les incidents de disponibilité, avec validation humaine pour les incidents d'intégrité (REC-1, REC-2).
2. **Accepter le risque résiduel de l'hôte unique** pour la phase pilote, et **inscrire au budget** les sauvegardes hors site (REC-5) puis le deuxième site (REC-9).
3. **Désigner les responsables** des rôles du PCA (directeur de crise, conformité, astreinte) et planifier un premier exercice de crise.